

Cirque Corporation

Corrective Action Procedure

Document ID: IS-CIRQ-PR-025-G

Category: ISMS Support Process

Division: Procedure

Type: Global

Version: 1.0

Effective Date: 2025-07-01

Review Date: 2026-07-01

Approved By: ISMS Owner / IT Manager

Generated: March 02, 2026

1. Purpose

The purpose of this procedure is to establish a systematic process for addressing nonconformities identified within Cirque's Information Security Management System (ISMS). It provides detailed steps for initiating, investigating, planning, implementing, verifying, and closing corrective actions, ensuring that the root causes of nonconformities are eliminated and recurrence is prevented, as per IS-CIRQ-P-023-G: Nonconformity and Corrective Action Policy.

****2. Scope****

2. Scope

This procedure applies to all identified nonconformities impacting Cirque's ISMS, regardless of their source (e.g., internal/external audits, security incidents, monitoring results, management reviews, stakeholder feedback). It covers all personnel involved in the corrective action process across all global operations (US, Taipei, China).

****3. Roles and Responsibilities****

3. Roles and Responsibilities

- ****ISMS Owner (e.g., Information Security Officer/IT Manager):****

Oversees the overall corrective action process, assigns CARs, tracks progress, and reports on the status of nonconformities.

- ****Originator:**** The individual who identifies and reports a nonconformity (e.g., Internal Auditor, security analyst, employee).

- ****Action Item Owner (Responsible Party):**** The individual or team responsible for investigating the nonconformity, performing root cause analysis, developing and implementing the corrective action plan.

- ****Verifier:**** The individual responsible for verifying the implementation and effectiveness of the corrective action (often the Originator or a designated auditor/ISMS staff member).

****4. Procedure****

4. Procedure

****4.1. Identification and Initiation of Corrective Action Request**

(CAR)** a. ****Frequency:**** As nonconformities are identified. b.

****Responsible:**** Originator, ISMS Owner. c. ****Steps:**** 1. ****Identify**

Nonconformity:** A nonconformity is identified (e.g., during an internal audit, an incident investigation, or routine monitoring). 2. ****Immediate**

Correction (Containment):** The immediate response to the nonconformity should be to contain its impact and correct the immediate issue (e.g., block unauthorized access, restore data). This is a temporary fix for the symptom. 3. ****Initiate CAR:**** The Originator completes the initial

sections of the IS-CIRQ-F-008-G: Corrective Action Request (CAR) Form, providing a clear and factual description of the nonconformity, the

relevant ISMS requirement violated, and any objective evidence. 4.

****Submit CAR:**** The completed CAR form is submitted to the ISMS Owner.

5. ****Assign CAR ID & Owner:**** The ISMS Owner logs the CAR in the CAR tracking system/register, assigns a unique CAR ID, and assigns an "Action Item Owner" (Responsible Party) based on the nature of the nonconformity and the relevant process owner. An initial target date for root cause analysis and action planning is set.

****4.2. Investigation and Root Cause Analysis (RCA)**** a. ****Frequency:****

Within the initial target date set by the ISMS Owner (e.g., 5-10

business days from CAR assignment). b. ****Responsible:**** Action Item

Owner. c. ****Steps:**** 1. ****Acknowledge CAR:**** The Action Item Owner

acknowledges receipt of the CAR. 2. ****Gather Information:**** Collect

additional relevant information, data, and evidence related to the

nonconformity. 3. ****Perform RCA:**** Conduct a systematic Root Cause

Analysis (e.g., using techniques like "5 Whys," Fishbone/Ishikawa

diagram, FMEA) to determine the underlying reasons why the nonconformity

occurred. This goes beyond the symptom to identify the systemic issues.

4. ****Document Root Cause:**** Record the identified root cause(s) on the

IS-CIRQ-F-008-G: Corrective Action Request (CAR) Form.

****4.3. Corrective Action Planning**** a. ****Frequency:**** Immediately

following RCA completion. b. ****Responsible:**** Action Item Owner. c.

****Steps:**** 1. ****Develop Action Plan:**** Based on the identified root

cause(s), develop a detailed corrective action plan outlining specific

actions required to eliminate the cause and prevent recurrence. 2.

****Define Deliverables & Responsibilities:**** For each action, specify

clear deliverables, assign responsibilities to individuals, and set

realistic completion dates. 3. ****Update CAR Form:**** Document the

corrective action plan on the IS-CIRQ-F-008-G: Corrective Action Request

(CAR) Form. 4. ****Obtain Approval:**** The Action Item Owner submits the

proposed corrective action plan to the ISMS Owner for review and approval.

****4.4. Implementation of Corrective Actions**** a. ****Frequency:**** As per the planned schedule. b. ****Responsible:**** Action Item Owner and assigned personnel. c. ****Steps:**** 1. ****Execute Actions:**** Implement the agreed-upon corrective actions according to the plan and deadlines. 2. ****Document Evidence:**** Maintain records and evidence of the implementation of each action (e.g., screenshots of configuration changes, training records, updated procedure documents, meeting minutes). 3. ****Update Status:**** Update the status of the CAR in the tracking system/register.

****4.5. Verification of Effectiveness**** a. ****Frequency:**** Upon completion of actions, within an agreed-upon timeframe (e.g., 30-60 days after implementation). b. ****Responsible:**** Verifier (e.g., Originator, ISMS Owner, Internal Auditor). c. ****Steps:**** 1. ****Review Evidence:**** The Verifier reviews the documented evidence of implementation. 2. ****Assess Effectiveness:**** The Verifier assesses whether the implemented corrective actions have effectively eliminated the root cause and prevented the recurrence of the nonconformity. This may involve: * Reviewing new performance data from monitoring (e.g., IS-CIRQ-PR-022-G). * Conducting follow-up interviews or observations. * Performing re-audits or re-tests of the affected control/process. 3. ****Document Verification:**** Record the results of the verification on the IS-CIRQ-F-008-G: Corrective Action Request (CAR) Form.

****4.6. Closure of CAR**** a. ****Frequency:**** Upon successful verification of effectiveness. b. ****Responsible:**** ISMS Owner (with Verifier's recommendation). c. ****Steps:**** 1. If the corrective actions are deemed effective, the Verifier recommends closure of the CAR to the ISMS Owner. 2. The ISMS Owner formally closes the CAR in the tracking

system/register. 3. If the corrective actions are *not* effective, the CAR is reopened, and the process reverts to Section 4.3 for further action planning and implementation.

****4.7. Review for Changes and Continual Improvement**** a. ****Frequency:****

Regularly, especially during management reviews. b. ****Responsible:****

ISMS Owner, Management Review Committee. c. ****Steps:**** 1. The ISMS Owner

shall periodically review the history of nonconformities and corrective

actions (e.g., quarterly) to identify recurring issues or systemic

weaknesses. 2. Information on nonconformities and corrective actions,

their root causes, and effectiveness shall be a key input to management

reviews (IS-CIRQ-PR-024-G). 3. This information contributes to Cirque's

continual improvement efforts (IS-CIRQ-P-024-G).

****5. Documentation****

5. Documentation

- IS-CIRQ-F-008-G: Corrective Action Request (CAR) Form (completed).

- CAR Tracking Register/System.

- Evidence of RCA activities.

- Evidence of corrective action implementation.

- Records of verification of effectiveness.

****6. Related Documents****

6. Related Documents

- IS-CIRQ-P-023-G: Nonconformity and Corrective Action Policy

- IS-CIRQ-F-008-G: Corrective Action Request (CAR) Form

- IS-CIRQ-PR-023-G: Internal Audit Procedure

- IS-CIRQ-P-021-G: Monitoring, Measurement, Analysis, and Evaluation Policy
- IS-CIRQ-PR-022-G: ISMS Performance Monitoring Procedure
- IS-CIRQ-P-022-G: Management Review Policy
- IS-CIRQ-PR-024-G: Management Review Procedure
- IS-CIRQ-P-024-G: Continual Improvement Policy
- IS-CIRQ-PR-020-G: Incident Response Procedure (Global Core)

****7. Review****

7. Review

This procedure will be reviewed at least annually, or sooner if there are significant changes to Cirque's ISMS, the process for managing nonconformities, or relevant standards.